BOUVIER Robin, MBAYE Fatou, THIEBAUD-GIRARD Paul-Victory

La méthodologie d’une attaque informatique

INTRODUCTION

De nombreux systèmes présentent certaines vulnérabilités ou une faiblesse soit au niveau de leur conception, de leur réalisation, de leur installation, de leur configuration ou même au niveau de leur utilisation. Ces vulnérabilités présentent alors une porte d’entrée à toute sorte d’attaque si jamais elle est exploitée par un attaquant et pourrait alors entraîner des dommages sur le bien en question. L’attaque est une action malveillante destinée à porter atteinte à la sécurité d’un bien. Elle représente la concrétisation d’une menace par l’exploitation d’une vulnérabilité. Autrement dit, l’attaque est l’exploitation d’une faille d’un système d’information (système d’exploitation, logiciel ou bien même de l’utilisateur) à des fins non connues par l’exploitant du système et généralement préjudiciables. Ce qui signifie que tout ordinateur connecté à un réseau est potentiellement vulnérable à une attaque.
Sur internet des attaques ont lieu en permanence, elles sont pour la plupart lancées automatiquement à partir de machines infectées (par des virus, chevaux de Troie, vers, etc.), à l'insu de leur propriétaire. L’attaque nécessite au préalable une série de positionnement et de recherches par son auteur. Ce qui amène à se poser la question de quelle est la méthodologie d’une attaque. Autrement dit comment se prépare et se réalise une attaque ?
Dans le développement, nous nous intéresserons d’abord au travail préalable d’un attaquant avant d’attaquer sa cible, ensuite à son mouvement latéral une fois dans le système et enfin comment se termine le travail d’attaque et ses impacts sur le système.

I / Travail préalable à l'intrusion

1) Identification et sélection de la cible

En réalité, la sécurité informatique repose uniquement sur la protection par mot de passe des différents composants informatiques qui composent le réseau. Une faille au niveau d'un des composants informatiques du réseau peut permettre l'intrusion de virus par un pirate informatique. Pour cela, les pirates utilisent différentes techniques pour forcer les mots de passe. Tout d'abord, ils doivent choisir une cible.

Un réseau d'entreprise peut être intéressant dans le cadre d'une attaque visant à récupérer des données supposées confidentielles, en vue de demander une rançon ou même de les revendre à d'autres entreprises. En réalité, les données d'entreprise peuvent être la cible de piratage pour l'espionnage industriel. Un pirate peut aussi choisir une entreprise pour des raisons politiques, dans le cas où il défendrait une cause contraire à la politique de l'entreprise, en raison d'une simple divergence d'opinion, ou encore pour des raisons strictement économiques en raison de l'impact du piratage sur l'entreprise. Dans ce contexte, il pourrait être plus rentable de pirater et de collecter les données pour les revendre à un prix plus élevé, ou au contraire, de les rendre contre une somme d'argent plus

importante. Les réseaux personnels sont moins souvent la cible des pirates en raison de l'intérêt limité que présentent généralement les données personnelles de quelqu'un. Cependant, cela peut être le cas lorsque cette personne occupe un poste important au sein d'une entreprise ou joue un rôle essentiel dans la société. En effet, l'intérêt des données convoitées n'est pas la seule condition de sélection pour la cyberattaque ; le niveau de sécurité et la gestion du risque sont également d'une grande importance pour le pirate. Un réseau privé, contrairement au réseau d'entreprise, peut être intéressant pour demander des rançons contre des données personnelles importantes. Ces attaques se basent sur la peur et ont des conséquences bien moindres.

2) Collecte d'information

Une fois la cible identifiée, le pirate recueille des informations sur la victime en observant ses réseaux sociaux, LinkedIn, ou autres. En entreprise, les différentes failles exploitées par un pirate incluent les failles humaines. Un employé qui ne protège pas correctement ses données et ses comptes, et qui laisse un accès à son ordinateur, que ce soit physiquement ou numériquement, est susceptible de permettre un accès direct au réseau de l'entreprise par le biais de son ordinateur ou appareil électronique.

Pour ce faire, le pirate devra installer un virus sur l'appareil. Cela peut se faire en profitant d'un accès physique non protégé à l'appareil, par exemple, si l'utilisateur laisse son appareil électronique sans surveillance dans un bar ou chez lui en présence de personnes non dignes de confiance. Cela pourrait permettre l'introduction d'une application ou d'un fichier malveillant via une clé USB ou un partage sans fil. Par ailleurs, le pirate peut également utiliser des techniques sociales pour convaincre une personne d'installer une application, par le biais d'e-mails se faisant passer pour une grande entreprise ou une entité officielle comme les impôts, incitant ainsi l'utilisateur ciblé à cliquer sur un lien d'installation. Les pirates doivent donc réussir dans cette première méthode à convaincre l'utilisateur ciblé d'installer lui-même le logiciel malveillant, souvent en le dissimulant dans une application couramment utilisée.

La faille humaine peut également se présenter lors de l'intervention de techniciens, voire de faux techniciens, qui pourraient avoir accès depuis l'intérieur de l'entreprise au serveur en passant directement par une connexion Ethernet aux données de l'entreprise visée, ce qui pourrait être l'une des méthodes les plus simples pour un pirate de pénétrer dans le réseau.

De plus, un pirate informatique pourrait recourir à différents dispositifs physiques, tels qu'un TAP réseau, qui est un dispositif permettant de surveiller un réseau informatique sans le perturber. Ce système pourrait permettre à un pirate informatique de mettre en place une surveillance, par exemple dans un parc de serveurs. Si un tel système est déployé et n'est pas découvert, il peut rester indétectable car il n'interfère pas avec la transmission.

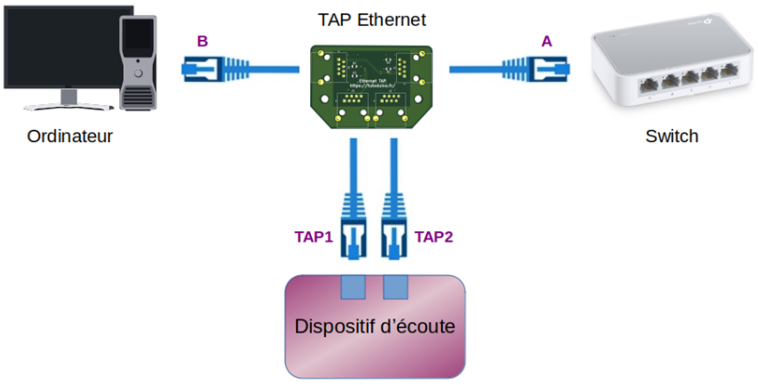


Figure 1: Schéma de la mise en place d'un TAP

Le pirate peut également utiliser de faux réseaux Wi-Fi comme moyen d'accès aux données. En effet, dans tout réseau informatique, tout ce qui est fait sur l'ordinateur demandant des ressources extérieures transite par le Wi-Fi. Si un tel réseau est malveillant, le pirate peut récupérer toutes ces données ou même faire télécharger des mises à jour corrompues afin d'introduire un virus dans le système. Pour cela le pirate pourra créer un réseau wi-fi public comme celui proposé dans un fast-food auquel pourra se connecter un utilisateur.

3) Exploitation des vulnérabilités

Les vulnérabilités résultent généralement de lacunes dans la conception, la réalisation ou l'exploitation d'un élément matériel ou logiciel du système, fréquemment dues à des défauts logiciels liés à des erreurs de codage ou à des méthodes défectueuses. Les logiciels installés peuvent parfois être mal protégés, notamment lors des mises à jour qui ne sont pas accompagnées de tests d'intrusion ou de sécurité à chaque nouvelle version. Ces vulnérabilités au niveau d'un logiciel peuvent entraîner l'interception ou la redirection des données (paquets IP) ou même donner directement accès aux pirates à l'administration de l'entreprise qui utilise le logiciel en question, s'il n'y a pas de vérification des données envoyées à l'application ou protection des entrées administrateur dans le cas souvent d'un oublie de retirer l'accès administrateur dans l'application à sa publication.[1]

Une forme de vulnérabilité système connue peut être l'injection SQL qui est est un ensemble de méthodes qui permet d'injecter dans une requête sql un morceau non prévu pouvant compromettre la sécurité du système d'arriver.[2]

Une autre vulnérabilité peut être le cross-site scripting (XSS), qui permet d'injecter du contenu dans une page internet. Ce contenu sera ensuite interprété et lu par le navigateur de l'utilisateur, pouvant ainsi le rediriger vers une autre page ou même récupérer la session de l'utilisateur sur le site en question.[3]

L'utilisation de logiciels ou systèmes d'exploitation non supportés et l'absence de mises à jour régulières constituent les failles de sécurité informatique les plus fréquentes en entreprise. Lorsqu'un logiciel est trop ancien, ses failles de sécurité sont alors connues de tous et ne sont plus corrigées par les éditeurs.

Au niveau logiciel, la faille la plus courante concerne les sites utilisant le protocole HTTP au lieu de HTTPS, ce qui signifie que les données ne sont pas chiffrées. Lorsqu'un utilisateur saisit des informations sur un tel site, en cas d'interception des données envoyées au serveur, elles ne sont pas protégées par un chiffrement ni sécurisées, ce qui permet à un pirate de récupérer les données partagées sur le site. Ce type de piratage est appelé l'attaque de l'homme du milieu, qui peut s'appliquer aux sites Internet, ainsi qu'à bien d'autres, en interceptant les données.

Les pirates peuvent également utiliser cette méthode dans le phishing en envoyant une copie de site officiel factice en HTTP pour récupérer ultérieurement les mots de passe de l'utilisateur.

Figure 2 : Exemple de Phishing

En fin de compte, une fois la cible choisie et les informations collectées concernant la cible, le pirate peut alors, en fonction des informations recueillies, pénétrer dans le système et en prendre le contrôle en forçant le passage. Cela demande souvent plus de temps et une programmation pour tester toutes les combinaisons possibles. Les pirates utilisent donc des programmes de déchiffrage et qui peuvent tester des mots de passe jusqu'à plusieurs milliers par seconde(où le terme déchiffrage désigne lire et tenter de traduire la combinaison du mot de passe)[4] . Néanmoins, il est possible de réaliser une attaque de force en privilégiant le forçage d'un mot de passe avec des combinaisons plus probables en fonction des informations collectées au préalable, en incluant des filtres dans le programme.

II/ Après l'intrusion

1) Le mouvement latéral

Après avoir pénétré dans le réseau par l'un des moyens précédemment évoqués, les hackers peuvent se déplacer librement à l'intérieur du réseau afin de rechercher des données sensibles. Une fois implantés dans le système, ils sont en mesure de rechercher des plans, des informations de cartes de crédit, des bilans comptables, ainsi que des identifiants d'administration Windows, qui sont particulièrement précieux.

Ils utilisent diverses techniques de pivotement pour se déplacer latéralement dans le réseau, principalement en exploitant les vulnérabilités de Windows. Par exemple, il existe la technique du "Pass-the-Hash", qui consiste à extraire les données de mot de passe stockées par Windows, puis à les transmettre directement à l'ordinateur cible pour s'y connecter.[5] Une autre technique couramment utilisée est celle de l'attaque dite "l'homme du milieu". Dans cette méthode, une machine est positionnée entre la machine cible et les serveurs auxquels elle tente d'accéder. Elle peut usurper son adresse IP pour la rediriger vers de faux serveurs, falsifier une requête ARP afin de lier l'adresse MAC de la machine attaquante à l'adresse IP de la machine cible, ou encore pratiquer une usurpation DNS qui redirige la cible vers de faux sites web. L'homme du milieu joue ainsi le rôle d'un routeur, lui permettant d'intercepter, de lire voire de modifier les données envoyées ainsi que les réponses des serveurs. [6]

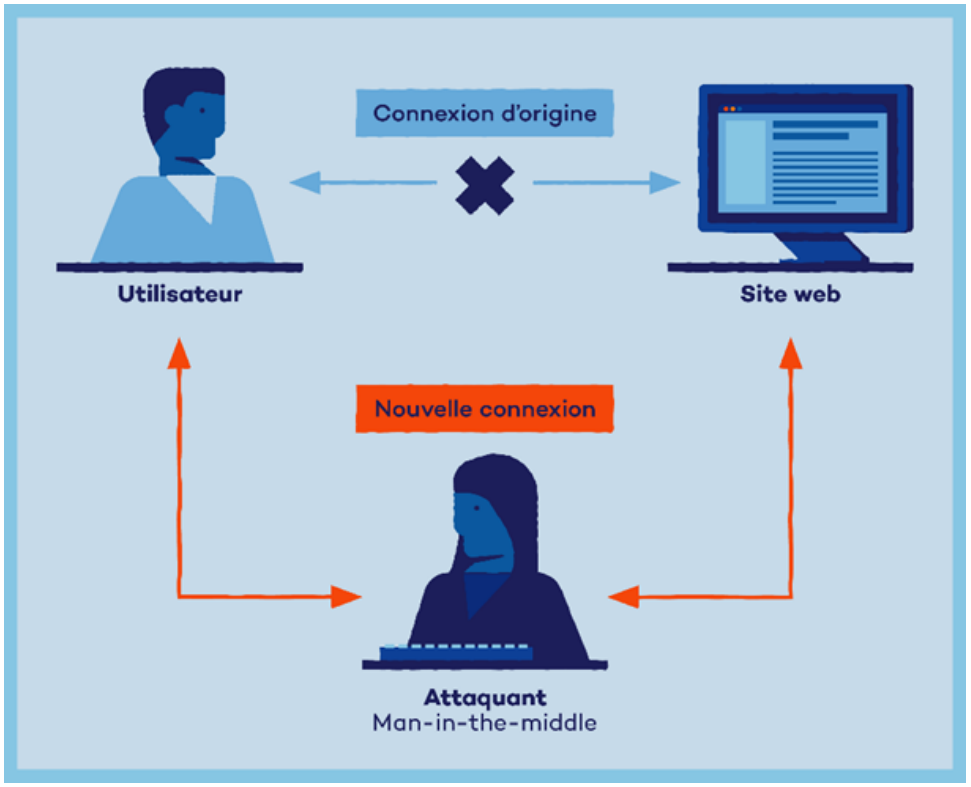


Figure 3. Schéma du Man in the middle (https://www.pandasecurity.com)

Un logiciel fréquemment employé pour ce type d'attaques est Mimikatz (voir Figure 2), qui a été développé par Benjamin Delpy, un professionnel français de la cybersécurité travaillant à la Banque de France. Son objectif initial était de mettre en évidence les vulnérabilités de Windows.

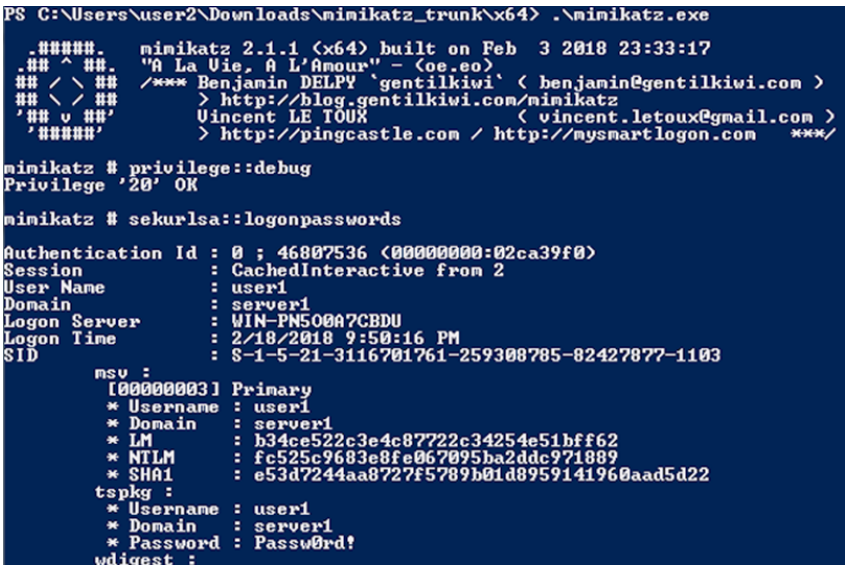


Figure 4. Image de Mimikatz (https://www.lemondeinformatique.fr)

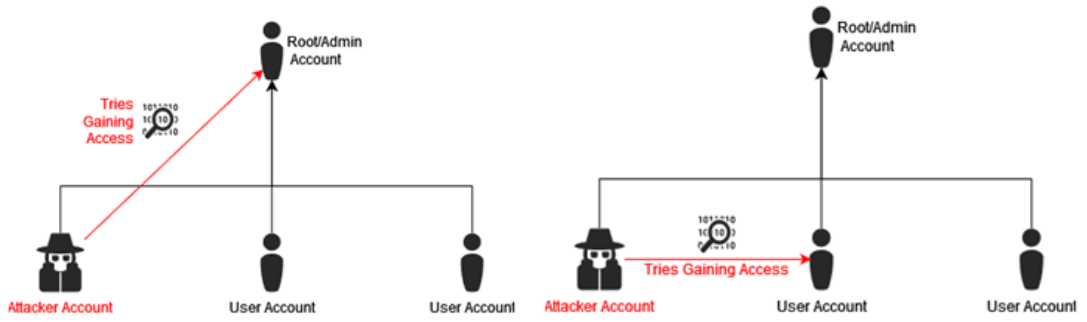
Le logiciel est désormais open source et son créateur continue de le mettre à jour afin que les entreprises puissent se protéger contre les attaques exploitant ces vulnérabilités.[7] Une autre méthode courante pour se déplacer à l'intérieur d'un réseau est l'utilisation des clients SSH. Cela requiert la possession d'identifiants, mais une fois obtenu, cela permet un accès distant à toutes les machines, donnant ainsi une grande liberté à l'attaquant au sein du réseau.

Pour se prémunir contre ces types d'attaques, il est essentiel de maintenir Windows régulièrement à jour afin de corriger les failles qui pourraient être exploitées. De plus, il est recommandé d'isoler les services en les exécutant sur des serveurs dédiés pour éviter la propagation de la menace. L'utilisation de l'authentification à deux facteurs, qui nécessite la validation de la connexion à partir d'au moins deux appareils différents, ainsi que la rotation régulière des mots de passe, contribuent également à prévenir de telles intrusions.[8]

2) <u>Acquisition des droits d'admin</u>

L'acquisition des droits d'administrateur peut se produire de deux manières différentes. L'attaquant peut soit obtenir les identifiants d'un compte administrateur, mais le plus souvent, il les obtient en accédant aux identifiants d'une session utilisateur normale et en obtenant les droits d'administrateur en exploitant des failles ou des bugs. Il existe également deux types d'escalade, à savoir l'escalade verticale et l'escalade horizontale.

L'escalade verticale se produit lorsqu'un utilisateur sans privilèges réussit à accéder à des fonctions ou à des ressources normalement réservées aux utilisateurs ayant des privilèges plus élevés. En revanche, l'escalade horizontale permet à un poste A d'accéder à des données d'un poste B ayant les mêmes privilèges, en général, que lui. Ces concepts d'escalade et d'acquisition de droits d'administrateur sont essentiels à comprendre pour se prémunir contre les attaques visant à exploiter les failles de sécurité et à protéger les systèmes informatiques. [9, 10]



Figures 5: Schémas de l'escalade de droit verticale et horizontale (https://www.baeldung.com)

Pour obtenir des logins il est aussi possible d'utiliser des techniques de crack de mot de passe par force brute donc en essayant toutes les combinaisons même si cela est peu efficace quand un mot de passe devient plus long ou complexe. Les pirates peuvent aussi utiliser un dictionnaire de mot de passe très courant qui sont souvent des suites de chiffres logique voir le même chiffre répété plusieurs fois. D'après security.org un mot de passe puissant est fait avec des lettres minuscules et majuscules ainsi que des chiffres et des symboles. La CNIL recommande aussi une phrase simple à se souvenir avec des chiffres et de la ponctuation.[11]

Pour réduire ces risques il faut évidemment corriger ces failles. De plus les antivirus peuvent bloquer des logiciels essayant de prendre avantage de ces failles, de plus il est possible d'utiliser ce qui s'appelle le Data Exécution Prevention, ce qui consiste à exécuter des fonctions seulement dans une partie de la mémoire pour éviter les problèmes liés aux failles.

3) Les actions des pirates

Maintenant qu'ils ont un accès total au réseau, les pirates peuvent faire beaucoup de choses avant de partir. Ils peuvent installer des logiciels malveillants qui leur permettent de rester sur le réseau. Ils peuvent évidemment copier toutes les données sensibles pour les revendre ensuite. D'après IBM, la vente de données volées a coûté 4,35 millions de dollars aux entreprises privées en France.[12] Certains demandent des rançons de plusieurs millions, voire des dizaines de millions, sinon ils détruisent les données, c'est le but des rançongiciels qui bloquent l'accès à une ou plusieurs machines jusqu'à ce que la rançon soit payée. Ces ransomwares coûtent en moyenne 4,54 millions de dollars aux entreprises qui en sont victimes, selon IBM.[12]

Figure 6: Exemple de ransomware, ici WannaCry[13] (https://en.wikipedia.org)

C'est le cas en ce moment de plusieurs casinos et hôtels à Las Vegas où un groupe de pirates russes, ALPHV, a pénétré le réseau de MGM Resorts. Ce ne sont pas les seules victimes de ce groupe, le Caesar's Palace a déjà été attaqué et a décidé de payer la rançon de 15 millions de $.[14] Pour éviter de se faire attraper après l'attaque, les pirates essaient de supprimer toute trace de leur passage en effaçant des données de fichiers log ou bien en utilisant des méthodes de spoofing, c'est-à-dire d'usurpation d'identité, ou en propageant des fausses informations pour tenter de rendre l'enquête confuse. De plus, ils demandent le plus souvent l'argent en crypto monnaie pour éviter qu'elle ne puisse pas être tracer.

<u>Conclusion :</u>

En somme, un système d'exploitation aussi sécurisé qu'il puisse être peut-être victime d'une attaque. Il existe des quantités de faiblesses pouvant être exploitées par une personne mal intentionnée désireuse d'accéder sans autorisation à des informations privées, ou d'empêcher un réseau informatique, qu'il soit filaire ou sans fil, de fonctionner correctement. Par ailleurs, toutes ces possibilités de nuire qui ont été énoncés ne se sont jamais appuyés sur le principe d'une intrusion de l'équipement réseau, qui est l'ultime moyen pour un pirate d faire ce qu'il veut au réseau, mais uniquement sur les faiblesses du protocole TCP/IP et des services réseaux assurant le fonctionnement correct de celui-ci. Alors pour attaquer, l'auteur étudie sa cible jusqu'à la moindre faille ce qui pousse alors à dire que la sécurité d'un réseau se repose sur la sécurité de son composant le plus faible. Et une fois sur le système un attaquant cherchera toujours une plus grande maîtrise du réseau sans se faire remarquer jusqu'à avoir le contrôle toujours du réseau et alors la tout ce réseau peut être pénalisé en fonction de ses motivations. Chaque utilisation de

l'informatique doit alors utiliser un réseau en se soumettant à un ensemble de règles représentant le socle minimale pour assurer la sécurité d'un réseau décrit par l'**ANSSI.**

Sources :

1. https://www.nowteam.net/principales-failles-de-securite-informatique-entreprise

2. https://fr.wikipedia.org/wiki/Injection_SQL

3. https://www.next-decision.fr/wiki/failles-securite-informatique

4.https://www.murielle-cahen.com/publications/p_intrusion.asp

5. https://www.crowdstrike.fr/cybersecurity-101/pass-the-hash/

6. https://www.pandasecurity.com/fr/mediacenter/securite/attaque-man-in-the-middle/

7. https://en.wikipedia.org/wiki/Mimikatz

8. https://www.cybermalveillance.gouv.fr/cybermenaces

9. https://youtu.be/ksjU3Iu195Q?si=0rynB3ZCBTQ6Eznm

10. https://www.baeldung.com/cs/privilege-escalation

11. https://www.cnil.fr/fr/generer-un-mot-de-passe-solide

12. https://www.blogdumoderateur.com/cout-vol-donnees-entreprise-chiffres-cles-conseils-mieux-proteger/#:~:text=En%20France%2C%20le%20coût%20de,9%2C44%20millions%20de%20dollars

13. https://en.wikipedia.org/wiki/WannaCry_ransomware_attack

14. https://www.youtube.com/watch?v=mH5fXUZyfpE